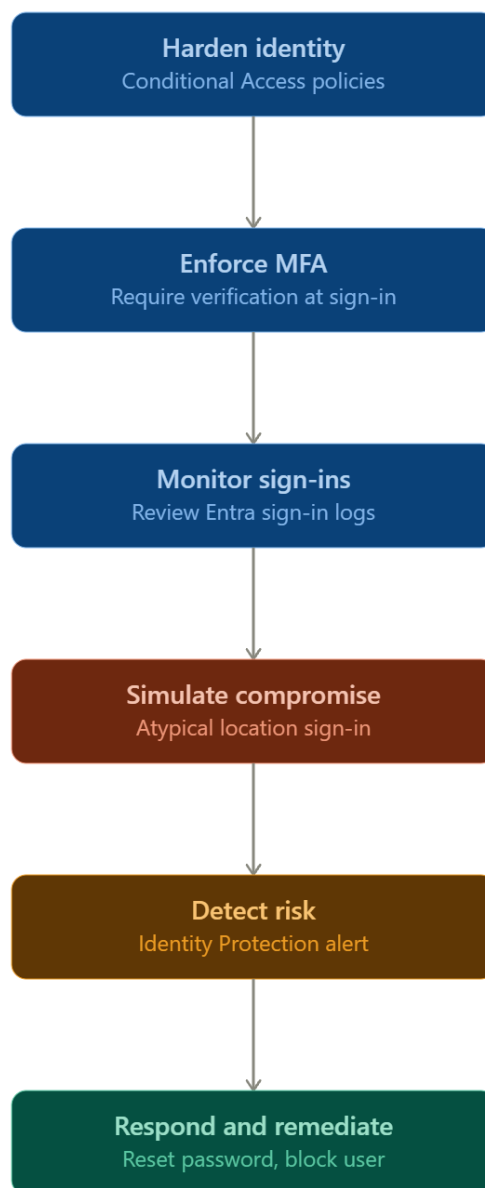


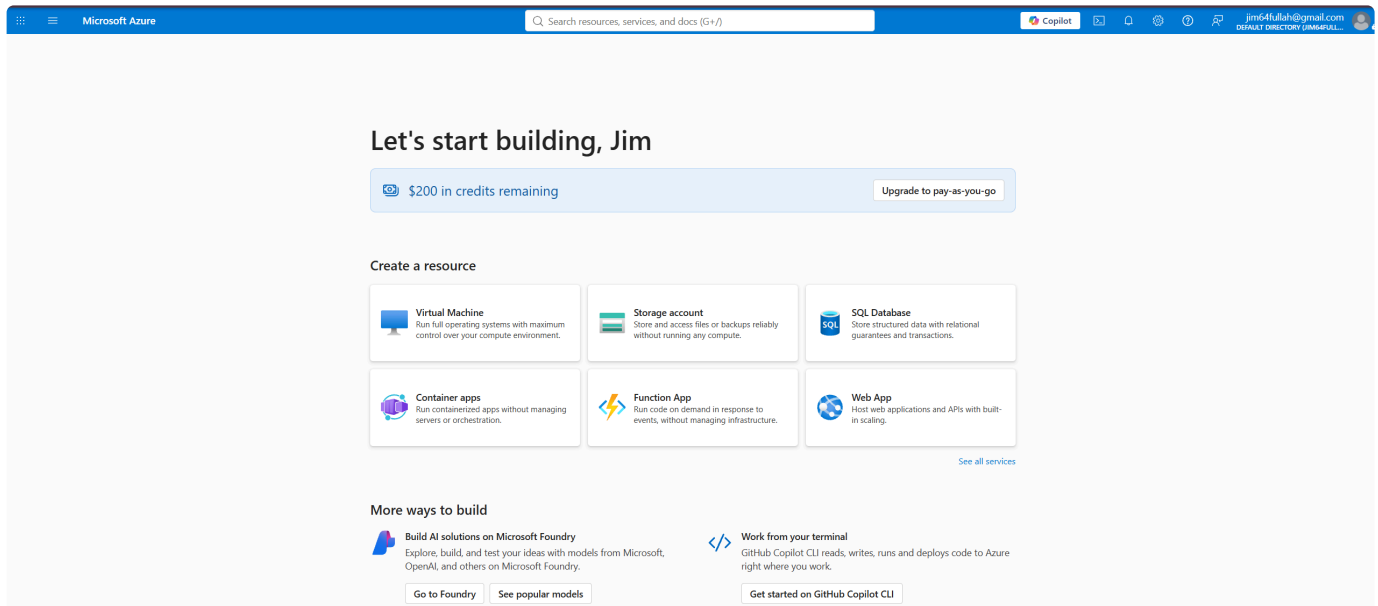
This lab focuses on the identity security layer of a cloud environment. Often the first thing attackers target since a single compromised account can bypass network defenses entirely. Using a Microsoft Entra ID tenant, I configured Conditional Access policies to enforce multi-factor authentication, block legacy authentication protocols, and require compliant devices for privileged roles. I then reviewed sign-in logs to understand how Entra ID evaluates and logs each authentication attempt against these policies.

To test detection capability rather than just prevention, I simulated a compromised account scenario (atypical sign in location/impossible travel) and used Microsoft Entra ID Protection to detect the risky sign in, investigate the risk signal, and walk through remediation steps password reset and account restriction. The goal was to build hands-on experience with the full identity security lifecycle: harden, monitor, detect, and respond.



Setup

For the lab I set up the a brand new azure account which gave me \$200 worth in credit to spend on any Azure services for the first 30 days.



go to Entra admin center search Licenses > All products and an option to enroll in the Entra ID p2 30 day trial will appear.

MICROSOFT ENTRA ID P2

With Microsoft Entra ID P2 you can gain access to advanced security features, richer reports and rule based assignments to applications. Your end users will benefit from self-service capabilities and customized branding.

[More information](#)

^ Free trial

Microsoft Entra ID P2 enhances your directory with additional features that include multifactor authentication, policy driven management and end-user self-service. [Learn more about features](#)

The trial includes 100 licenses and will be active for 30 days beginning on the activation date. If you wish to upgrade to a paid version, you will need to purchase Microsoft Entra ID P2. [Learn more about pricing](#)

Microsoft Entra ID P2 is licensed separately from Azure Services. By confirming this activation you agree to the [Microsoft Online Subscription Agreement](#) and the [Privacy Statement](#).

Activate

Microsoft Entra ID P2 - Trial

One month free with payment details

Subscription & account details

Sign-in details

Add payment, confirm & complete order

Try free for one month

Before you start your trial, you need to set up your subscription by adding up to 25 free users.

Product name	Unit price	Quantity	Subtotal
Microsoft Entra ID P2 Pay Monthly, 1-year subscription	\$10.50 user/month	1	\$10.50

> Billing settings - update subscription length and billing frequency

Subtotal after trial (tax not included)	\$10.50
Payment due today (tax not included)	\$0.00

Details of your order after your trial ends on October 22, 2026. You'll be billed monthly after this date. After the trial ends, it will become a 1-year paid subscription. You won't be charged if you cancel before October 22, 2026. After that date, you have 7 days to cancel for a pro-rated refund. [Learn more about canceling](#)

Next

Microsoft Entra ID P2 is the licensing tier that enables risk based security features like Identity Protection and Conditional Access risk policies, which this lab will rely on to detect and respond to compromised accounts.

Licenses | Licensed features

ALPHA HEALTH HOME SERVICES

Overview

Diagnose and solve problems

Manage

Licensed features

All products

Self-service sign up products

Activity

Audit logs

Help

Support + Troubleshooting

The current license plan for this Microsoft Entra tenant is Microsoft Entra ID P2. For how to purchase/upgrade a Microsoft Entra ID paid license, or if you just want to know the features included in each edition, see [Microsoft Entra ID pricing page](#).

Features	Description	Feature available
Directory objects	Object limit of 500,000 with Microsoft Entra ID Free license; no limit for other licenses Learn more	Yes
Single Sign-On (SSO)	Support for unlimited apps with Microsoft Entra ID Free Learn more	Yes
User provisioning	Learn more	Yes
Federated Authentication (ADFS or 3rd party IDP)	Learn more	Yes
User management (add/update/delete)	Learn more	Yes
Group management (add/update/delete)	Learn more	Yes
Device registration	Learn more	Yes
Cloud Authentication (Pass-Through Auth, Password Hash sync, Seamless SSO)	Learn more	Yes
Microsoft Entra Connect Sync (extend on-premises directories to Microsoft Entra ID)	Learn more	Yes
Self-Service Password Change for cloud users	Learn more	Yes
Microsoft Entra join: desktop SSO and administrator bitlocker recovery	Learn more	Yes
Password Protection (global banned password)	Learn more	Yes
Multifactor authentication for administrator roles	Learn more	Yes
Basic security and usage reports	Learn more	Yes
Microsoft Entra ID features for guest users	Learn more	Yes
Company branding (customization of logon and logout pages, access panel)	Learn more	Yes
Multifactor authentication (phone and sms)	Learn more	Yes
Group access management	Learn more	Yes
Service Level Agreement (SLA)	Learn more	Yes

In the Entra admin center go to users on the left navigation panel and create 3 new users, 1 admin account (testadmin) and 2 standard user accounts (testuser1&2).

Create new user ...

Create a new internal user in your organization

[Basics](#)
[Properties](#)
[Assignments](#)
[Review + create](#)
Create a new user in your organization. This user will have a user name like alice@contoso.com. [Learn more](#)

Identity

User principal name * @ [Domain not listed? Learn more](#)

Mail nickname * ☒ Derive from user principal name

Display name *

Password * ☒ Auto-generate password

Account enabled ☒

Home > Custom domain names

Users ...
ALPHA HEALTH HOME SERVICES

+ New user Edit Delete Download users (Preview) Bulk operations Refresh Manage view Per-user MFA Got feedback?

Search users Add filter

4 users found

	Display name ↑	User principal name ↑	User type	Is Agent	On-premises sy...	Sign-in identifiers	Company name	Creation type
☐	Jim Fullah	JimFullah@ALPHA...	Member	No	No	View		
☐	Test Admin	testadmin@ALPHA...	Member	No	No	View		
☐	Test User 1	testuser1@ALPHA...	Member	No	No	View		
☐	Test User 2	testuser2@ALPHA...	Member	No	No	View		

Once testadmin is created, go to Roles & admins > search Global Administrator . Add assignments > select testadmin, so it actually has the elevated permissions you'll want for later scenarios. The Global Administrator role can manage all aspects of Microsoft Entra ID and Microsoft services that use Microsoft Entra identities.

Home > Licenses & licensed features > Roles and administrators > All roles > Global Administrator

Global Administrator | Assignments ...

Diagnose and solve problems

+ Add assignments Remove assignments Download assignments Refresh Manage in PIM Got feedback?

You can also assign built-in roles to groups now. [Learn More](#)

Search

Search by name

Type

All

Name	UserName	Type	Scope
☐ Test Admin	testadmin@/	onmicrosoft.com	User

Successfully added assignment
Successfully added assignment Test Admin

The Global Administrator role can manage all aspects of Microsoft Entra ID and Microsoft services that use Microsoft Entra identities.

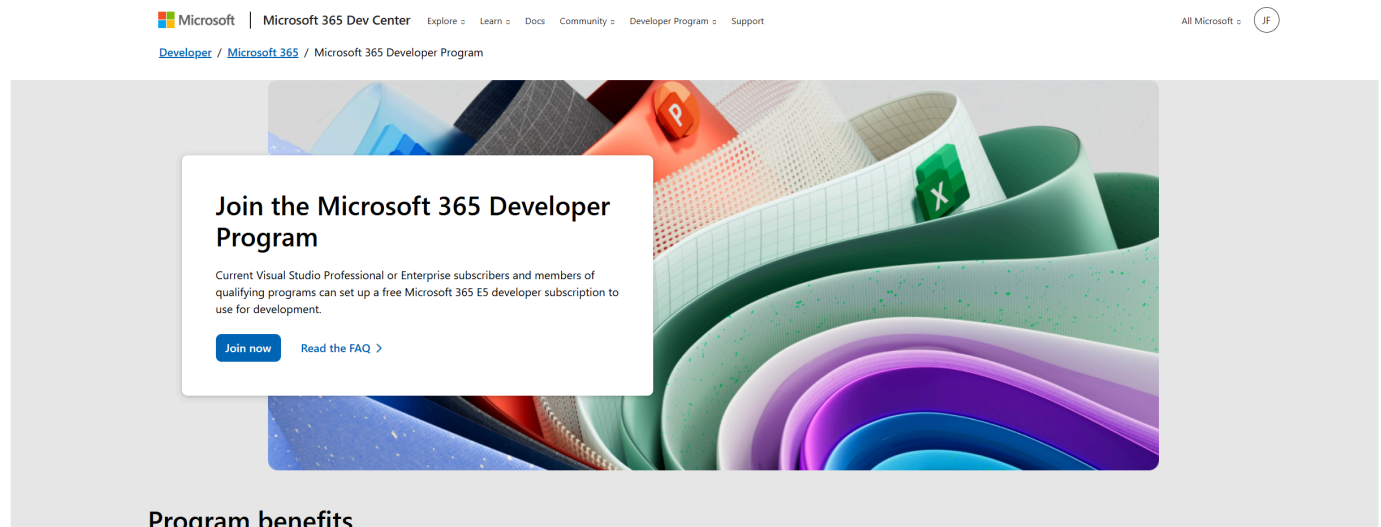
(Alternative Option)

The Microsoft 365 Developer Program <https://developer.microsoft.com/en-us/microsoft-365/dev-program>

Check if you qualify for the. If eligible, this gives you a free, renewable Microsoft 365 E5 sandbox that includes Entra ID P2 pre-populated with 25 fake users for testing attack vector.

It gives you a free instant sandbox tenant with an E5 license already included which comes with Entra ID P2 baked in, no credit card, renewable every 90 days as long as you're actively using it. This is the standard workaround cybersecurity students use for exactly this lab, since it sidesteps the billing-account requirement completely.

This would of be my ideal setup but unfortunately my account was not eligible for the sandbox



Enable MFA enforcement

Now i will build a baseline Conditional Access policy that will require MFA for all users, all cloud apps. This will make it so your account will require two or more different pieces of evidence to prove your identity before gaining access.

Go to Conditional Access and create a new policy with a name related to MFA. Ensure that
User - All users

Target resources - all resources

grant - check multi factor authentication

enable policy - report only then select on
are selected.

Ensure you security defaults are disabled or else you wont be able to turn it on.

Home > [Terms Of Use](#) > Conditional Access | Overview

New ...

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.

[Learn more](#) 

Name *

Require MFA for all Users



Assignments

Users ⓘ

[All users](#)

Target resources ⓘ

[All resources \(formerly 'All cloud apps'\)](#)

Network ⓘ

[Not configured](#)

Conditions ⓘ

[0 conditions selected](#)

Access controls

Grant * ⓘ

[1 control selected](#)

Session * ⓘ

[0 controls selected](#)

Enable policy

[Report-only](#)

On

Off

>

Cancel

Per-user multifactor authentication ...



Sign in

Now we will be prompted to download Microsoft Authenticator



testuser1@A...onmicrosoft...

Install Microsoft Authenticator



Install the app on your mobile device, then come back here to continue.



[Set up a different authentication app](#)

Next



← testuser1@A

.onmicro...

Scan the QR code



Use the Microsoft Authenticator app to scan the QR code. This connects the app to your account.

Then come back and select **Next**.

[Can't scan the QR code?](#)

Next

After setting up Microsoft Authenticator and login in we will have to update our password.



testuser1@...onmicrosoft.c...

Update your password

You need to update your password because this is the first time you are signing in, or because your password has expired.

Current password

New password

Confirm password

Sign in

to ensure this is working properly we will sign in and out one more time



testuser1@...

...onmicrosoft.c...

Approve sign in request



Open your Authenticator app and approve the request. Enter the number if prompted.

58

Didn't receive a sign-in request? **Swipe down to refresh** the content in your app.

[I can't use my Microsoft Authenticator app right now](#)

[More information](#)

(optional) you can add an addition security measure such as signing in with your face, fingerprint, or PIN. The measure depends on what device you log in. My case would Passkey saved on to password manager but you mobile end users it could be face id or fingerprint.



testuser1@

.onmicrosoft.c...

Let's keep your account secure

We'll help you set up another way to verify it's you.

[Not now](#)

[Next](#)



testuser1@Al

.onmicrosoft....

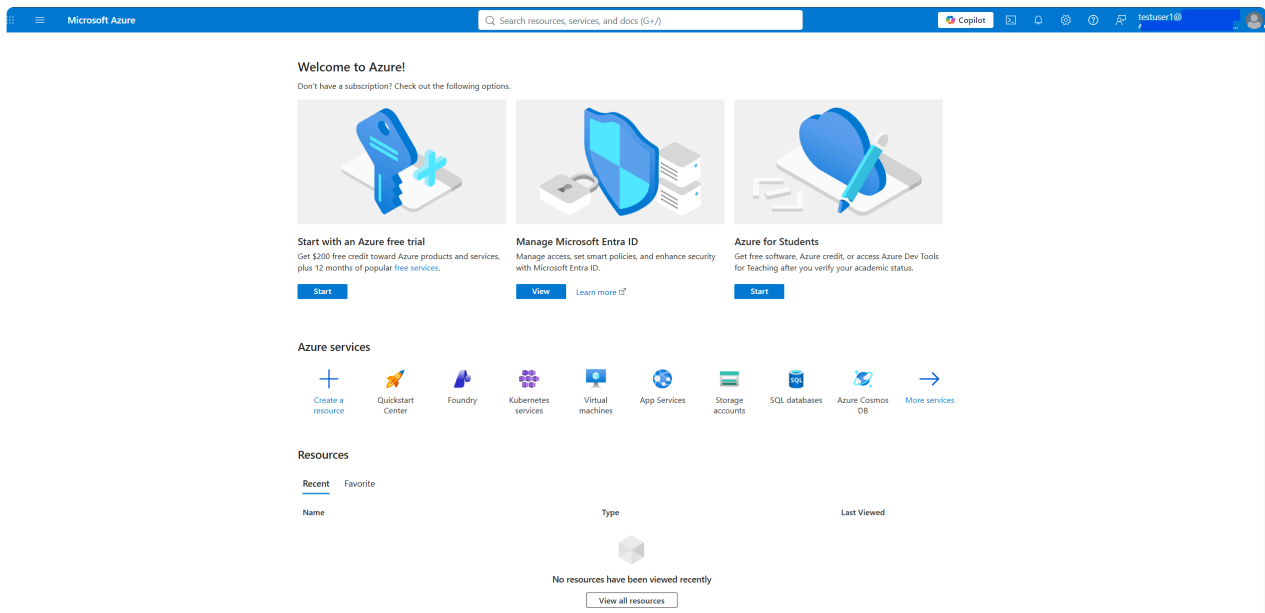
✓ **Passkey created**



You can now use your face, fingerprint or PIN to sign in to your account.

[Done](#)

We are now logged in to testuser1 with mfa enabled but we will repeat all steps for testadmin and ignore testuser2.



Pick an account to continue to Microsoft Azure



Test User 1
testuser1@oft.com
Signed in

S.onmicros:



Test Admin
testadmin@A
oft.com
Signed in

onmicros:

Build layered Conditional Access policies

Block Legacy Authentication

Lets create a new conditional access policy named block legaacy authentication. This policy will stop any sign in attempt that uses older, outdated communication protocols which cannot support multi factor authentication) .Go to Conditional Access > add New policy. Name it 'Block Legacy Authentication'.

User- All users (excluding break glass admin, which is the original).

Target resources- All cloud apps.

Conditions - Client apps check only 'Exchange ActiveSync clients' and 'Other clients'.

Grant- Block access.

Enable policy- Report-only first, then switch to On once confirmed.

New ...

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.
[Learn more](#)

Name *

Block Legacy Authentication ✓

Assignments

Users ⓘ

[All users included and specific users excluded](#)

Target resources ⓘ

[All resources \(formerly 'All cloud apps'\)](#)

Network ⓘ

[Not configured](#)

Conditions ⓘ

[1 condition selected](#)

Access controls

Grant * ⓘ

[Block access](#)

Session * ⓘ

[0 controls selected](#)

Enable policy

Report-only

On

Off

Create

Risk Based Sign in policy

Now we will create a risk based sign in policy. This policy will automatically evaluate the threat level of every login attempt in real time and triggers security controls like blocking access or requiring MFA.

create a new policy, name it 'Risk-Based Sign-In MFA'.

Users - All users (exclude break glass admin).

Target resources - All cloud apps.

Conditions - User risk or Sign-in risk: set Sign-in risk to Medium and above.

Grant - Require multifactor authentication.

Enable policy:- Report only first. This one requires P2 which we signed up for earlier.

Risk Based Sign in MFA ...

Conditional Access policy

 Delete  View policy information  View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.

[Learn more](#) 

Name *

Risk Based Sign in MFA

Assignments

Users ⓘ

[All users included and specific users excluded](#)

Target resources ⓘ

[All resources \(formerly 'All cloud apps'\)](#)

Network ⓘ

[Not configured](#)

Conditions ⓘ

[1 condition selected](#)

Access controls

Grant * ⓘ

[1 control selected](#)

Session * ⓘ

[0 controls selected](#)

Enable policy

Report-only ☒ On ☐ Off

Require Compliant Device for Admins

New policy, name it 'Require Compliant Device Admin Roles'

This policy requires that any sign in to a Global Administrator account come from a device enrolled in Intune and marked as compliant with organizational security standards.

Users: Select users and groups > Directory roles > Global Administrator.

Target resources: All cloud apps.

Grant: Require device to be marked as compliant.

Enable policy: Report only keep this one in Report-only permanently unless you actually enroll a device in

Intune, since turning it On will lock testadmin out entirely (no compliant device exists in this lab).

Require Compliant Device - Admin roles

Conditional Access policy

 Delete  View policy information  View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.
[Learn more](#)

Name *

Require Compliant Device - Admin roles

Assignments

Users ⓘ

[Specific users included and specific users excluded](#)

Target resources ⓘ

[All resources \(formerly 'All cloud apps'\)](#)

Network ⓘ

[Not configured](#)

Conditions ⓘ

[1 condition selected](#)

Access controls

Grant * ⓘ

[1 control selected](#)

Session * ⓘ

[0 controls selected](#)

Enable policy

Report-only On Off

Save

All roles have been set up

Policy name	Created by	State	Alert
Block Legacy Authentication	USER	On	
Require Compliant Device - Admin roles	USER	Report-only	
Require MFA for all Users	USER	On	
Risk Based Sign in MFA	USER	On	

Review sign-in logs

In the condition access > monitoring tab we 2 options to view logs from, sign in Logs and Audit Logs. Sign in logs record authentication events and login attempts, while audit logs track configuration and

administrative changes made within the tenant.

In sign in logs here we can view the user, application, status, ip and location. We can see how our testuser1 and admin account logged in successfully into azure portal.

Oce19c9c-c916-4328...	Jim Fullah	Azure Portal	Success	0
8595122a-27e8-41e...	Test User 1	Azure Portal	Success	0
de606f23-1fb2-4d93...	Test User 1	Azure Portal	Success	0
c25c554c-3752-4a8f...	Test Admin	Azure Portal	Success	0

Jim Fullah	Microsoft 365 Admin portal	min...	Interrupted	50140	19
Jim Fullah	Microsoft 365 Admin...	Success		0	19
Jim Fullah	Microsoft 365 Admin...	Failure		50126	19
Jim Fullah	Microsoft 365 Admin...	Failure		50126	19

Date	Request ID	User	Application	Status	Sign-in error co...	IP address	Location
9/24/2026, 2:06:20 PM	9aace723-9c3e-4a0f...	Jim Fullah	Azure Portal	Success	0		Fairfax, Virginia, US
9/24/2026, 2:06:05 PM	90e04904-8827-49b...	Jim Fullah	Office365 Shell WCS...	Success	0		Fairfax, Virginia, US
9/24/2026, 2:06:05 PM	de4b6c09-e290-425...	Jim Fullah	Office365 Shell WCS...	Success	0		Fairfax, Virginia, US
9/24/2026, 2:06:05 PM	8dc3f3f2-bad2-46e1...	Jim Fullah	Office365 Shell WCS...	Success	0		Fairfax, Virginia, US
9/24/2026, 2:06:01 PM	469ebbd7-a59d-47c...	Jim Fullah	Microsoft 365 Admin...	Success	0		Fairfax, Virginia, US
9/24/2026, 2:05:59 PM	bb3db143-3ecf-46d...	Jim Fullah	Microsoft 365 Admin...	Success	0		Fairfax, Virginia, US
9/24/2026, 2:05:15 PM	469ebbd7-a59d-47c...	Jim Fullah	Microsoft App Acces...	Success	0		Fairfax, Virginia, US
9/24/2026, 2:05:06 PM	469ebbd7-a59d-47c...	Jim Fullah	Microsoft 365 Admin...	Interrupted	50203		Fairfax, Virginia, US
9/24/2026, 2:04:50 PM	8c1497a8-b04b-4fbe...	Jim Fullah	Microsoft 365 Admin...	Success	0		Fairfax, Virginia, US
9/24/2026, 2:04:47 PM	2cb1e3ef-e6b9-4fb6...	Jim Fullah	Microsoft 365 Admin...	Interrupted	50140		Fairfax, Virginia, US
9/24/2026, 2:04:29 PM	4cbc4b8a-731e-4af0...	Jim Fullah	Microsoft 365 Admin...	Success	0		Fairfax, Virginia, US
9/24/2026, 2:00:43 PM	69e07074-4139-49e...	Jim Fullah	Microsoft 365 Admin...	Failure	50126		Fairfax, Virginia, US
9/24/2026, 1:54:27 PM	07f56413-f7a9-4022...	Jim Fullah	Microsoft 365 Admin...	Failure	50126		Fairfax, Virginia, US
9/24/2026, 1:53:55 PM	f6ea7039-Saa4-4bb3...	Jim Fullah	Microsoft 365 Admin...	Failure	50126		Fairfax, Virginia, US
9/24/2026, 1:46:54 PM	f7dd8e7f-08ab-4767...	Jim Fullah	Azure Portal	Failure	50126		Fairfax, Virginia, US

You can view additional information once clicking on a log.

Activity Details: Sign-ins



Basic info	Location	Device info	Authentication Details	Conditional Access	Report-only
Date	9/23/2026, 9:30:36 PM				
Request ID	0ce19c9c-97b6-4238-bc94-b42ba068180				
Correlation ID	01a0d109-20260923-1111-1111-1111-111111111111				
Authentication requirement	Single-factor authentication				
Agent Type	Not Agentic				
Status	Success				
Continuous access evaluation	No				
Additional Details	MFA requirement satisfied by claim in the token				
Follow these steps:					
Troubleshoot Event	Launch the Sign-in Diagnostic. 1. Review the diagnosis and act on suggested fixes.				
User	Jim Fullah				
Username	jimfullah@al-00000000-00000000-00000000-000000000000				
User ID	f9f2623f-902e-4121-98a4-2aef079a1803				
Sign-in identifier					
Session ID	008cb78a-1ab1-4d8a-178a-0001267883c1				
Root actor ID					
App owner tenant ID	f8cdef31-a31e-4b4a-93a4-85371a01020a				
Resource owner tenant ID	f8cdef31-a31e-4b4a-93a4-85371a01020a				

In this case, only "Require MFA for all Users" applied and succeeded Block Legacy Authentication, Risk-Based Sign-In, and Require Compliant Device didn't trigger, since none of their specific conditions were met for this sign in. This confirms Conditional Access evaluates policies individually per sign in rather than applying all configured policies uniformly.

Basic info	Location	Device info	Authentication Details	Conditional Access	Report-only	...
Authentication Policies Applied						
Conditional Access						
ate	Authentication met...	Authentication met...	Succeeded	Result detail	Requirement	
23/2026, 1:18:48 PM	Previously satisfied		true	MFA requirement satis...		

The Device info tab confirms this sign in came from a device marked Compliant: No, Managed: No. This is the exact condition the "Require Compliant Device - Admin roles" policy checks against meaning if that policy were switched to On rather than Report-only, this sign-in would have been blocked. This is why the policy was kept in Report only mode, no device in this lab environment is currently compliant, so enforcing

it would lock out testadmin entirely.

Basic info	Location	Device info	Authentication Details	Conditional Access	Report-only
Device ID					
Browser	Chrome 153.0.0				
Operating System	Windows10				
Compliant	No				
Managed	No				
Join Type					

The Audit Logs tab shows us the service ,category, activity, status, status reason, target and initiated by. This track what changes were made to your system, resources, or user. This will be helpful for compliance tracking, governance, and finding out who added a user to a privileged group, deleted an application, or reset a password.

Conditional Access | Audit logs

Microsoft Entra ID

Overview

Policies

Deleted Policies

Phased rollout

Insights and reporting

Diagnose and solve problems

Manage

Named locations

Custom controls (Preview)

Terms of use

VPN connectivity

Authentication contexts

Authentication strengths

Classic policies

Monitoring

Sign-in logs

Audit logs

Troubleshooting + Support

New support request

<< Download Export Data Settings Refresh Columns Got feedback?

This view will soon be replaced with a view that includes custom security attribute logs, infinite scrolling, and column reordering. Try out our new audits preview. →

Date : Last 24 hours Show dates as : Local Service : All Category : All Activity : All Add filters

Date	Service	Category	Activity	Status	Status reason	Target(s)	Initiated by (actor)
9/25/2026, 9:28:52 PM	B2C	Authentication	Validate user authentication	Success	Token is valid	00000000-0000-0000-0000-...	JimFullah@A
9/25/2026, 6:36:55 PM	B2C	Authentication	Validate user authentication	Success	Token is valid	00000000-0000-0000-0000-...	JimFullah@A
9/25/2026, 6:24:22 PM	B2C	Authentication	Validate user authentication	Success	Token is valid	00000000-0000-0000-0000-...	JimFullah@A

Using the condition access filter in the sign in logs further proves that our conditional access was not applied to every account. The filter also shows that not every case will require multifactor authentication.

Conditional Acc...	Agent Type	Authentication r...
Not Applied	Not Agentic	Single-factor authen...
Not Applied	Not Agentic	Single-factor authen...
Not Applied	Not Agentic	Single-factor authen...
... Not Applied	Not Agentic	Single-factor authen...
... Not Applied	Not Agentic	Single-factor authen...
... Success	Not Agentic	Multifactor authentic...
... Success	Not Agentic	Multifactor authentic...
... Success	Not Agentic	Multifactor authentic...
... Success	Not Agentic	Multifactor authentic...

Simulate a compromised account

In order to simulate a compromised account, I will sign in as testuser1 using a VPN in an incognito window to trigger impossible travel. Impossible travel is a risk detection that flags two sign ins from the same account happening in places too far apart for real travel to have occurred in that amount of time. First we will log in normally into testuser1 without any VPN or incognito, then we will log into testuser1 from a different country in incognito shortly after.

testuser1 log in is completed at 2:47PM on standard chrome tab

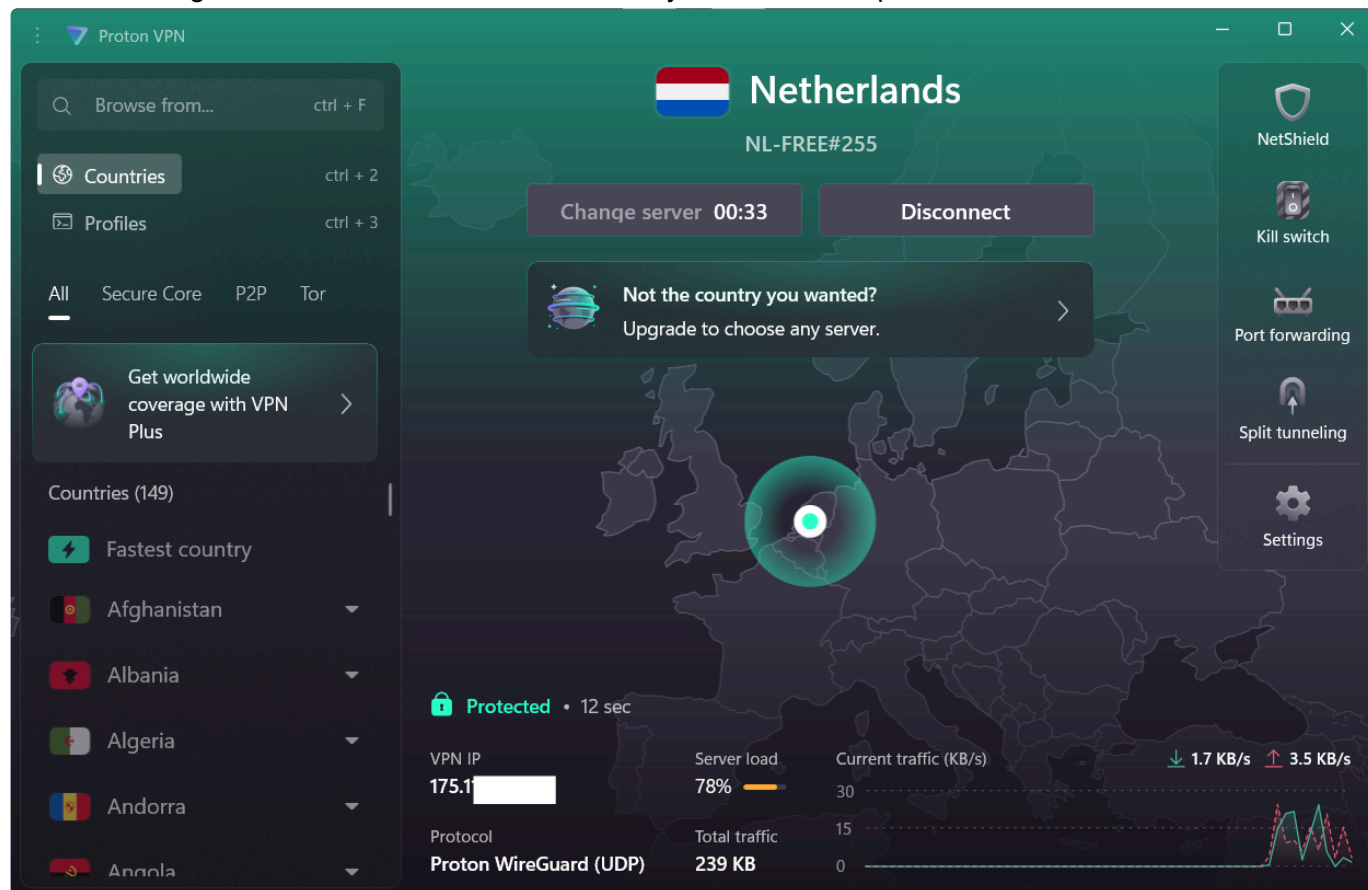
The screenshot displays the Microsoft Entra admin center interface. The left sidebar contains navigation links for Home, Favorites, Entra ID, Overview, Users, Groups, Devices, Agents, Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Tenant governance, Domain services, Conditional Access, Multifactor authentication, Identity Secure Score, Authentication methods, Account recovery, and Password reset.

The main content area shows the user profile for **testuser1@alphahealth.com** (Tenant ID: 9dc...). The profile includes statistics for users (4), groups (0), devices (0), and apps (0). A "Users at high risk" section indicates the user is "Unauthorized" and "You don't have access to this data." Below this, a "Shortcuts" section lists various administrative tasks like "User sign-ins", "Audit logs", "Authentication Methods", "Blocked users", "Domain names", "Unused service principals", "Manage tenants", "Named locations", "Cross-tenant Access Policies", and "Tenant restrictions".

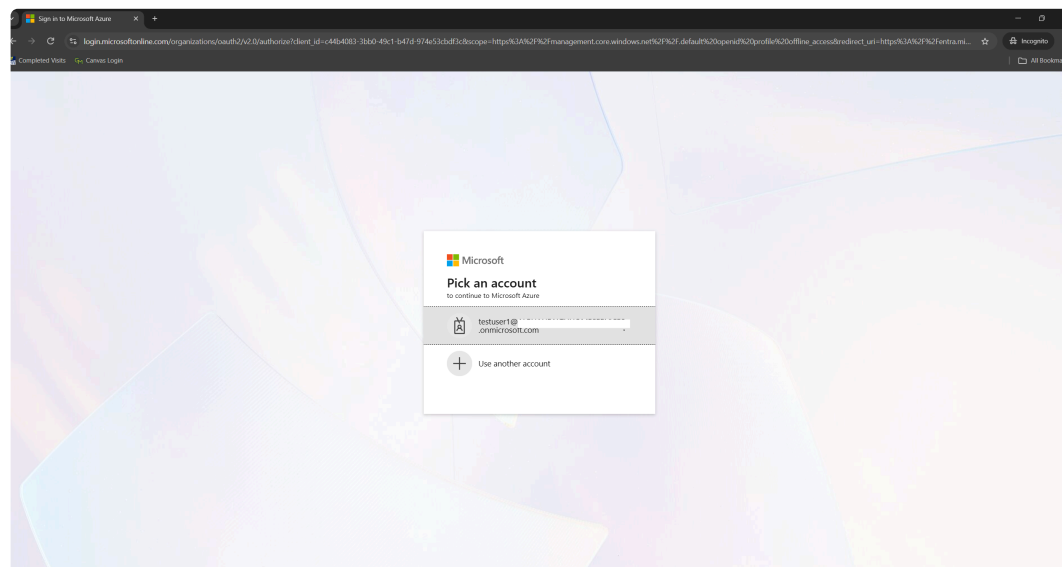
The bottom section, "Get the most out of your licenses and subscriptions", features "Deployment guides" for Microsoft Entra plan (Entra ID Premium P2) and "Tenant status" (Microsoft Entra Connect is Disabled). The "Last sync" status shows "Sync has never run".

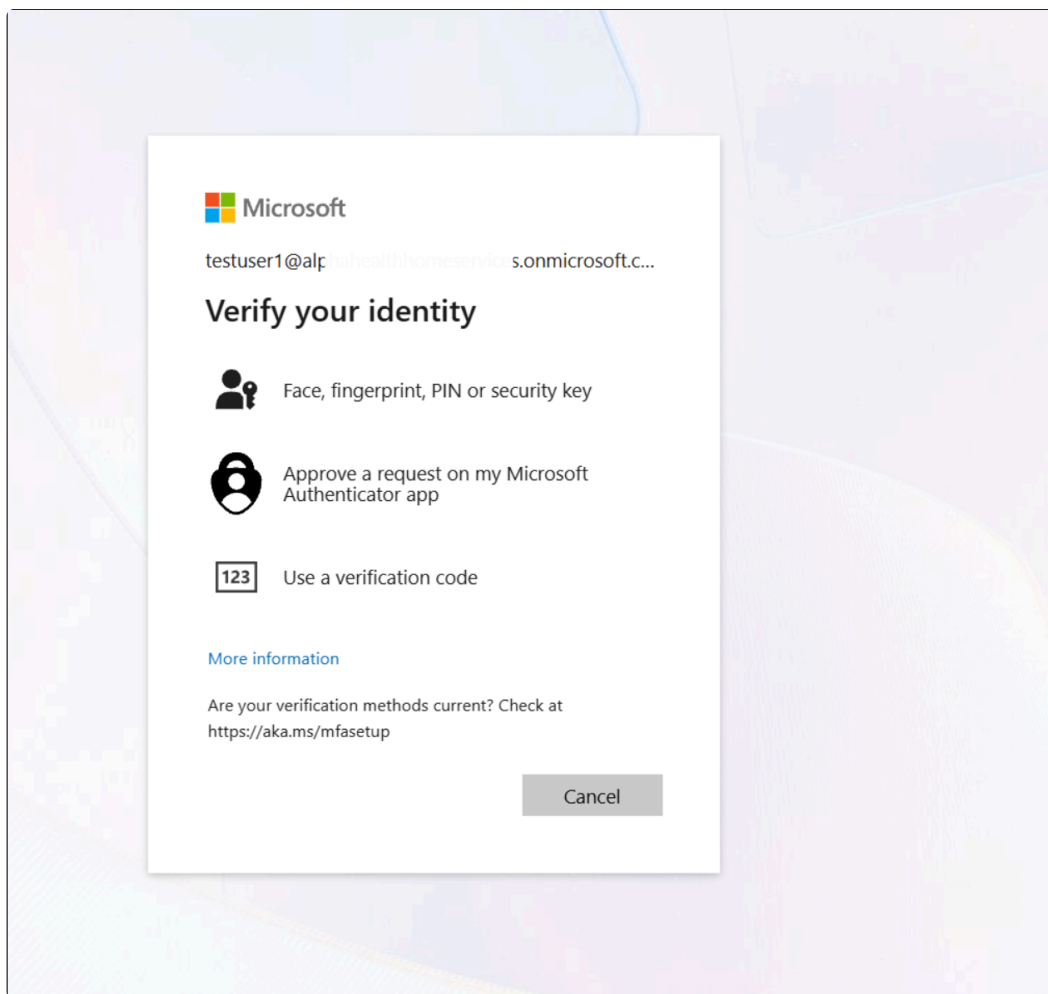
The Windows taskbar at the bottom shows the time as 2:47 PM on 9/26/2026, with a weather forecast of 67°F and light rain.

Now we will sign out of the session, and immediately connect to the proton VPN.



For this scenario, let's assume the attacker also somehow has access to a method of verification.





After successfully logging into the account, we will disconnect the vpn and close tab.

In a real world scenario, an account like testuser1 is typically compromised through phishing, credential stuffing (reusing passwords leaked in other breaches), or MFA fatigue attacks (bombarding a user with approval requests until one is accidentally approved). This lab doesn't simulate the initial compromise itself, but instead simulates the resulting behavior an attacker would exhibit from signing in with valid credentials from an unfamiliar location. This is the pattern Identity Protection is designed to catch regardless of how the credentials were originally obtained.

To be thorough, I tested this using two different VPN providers across three locations: Netherlands and Hong Kong through Proton and Windscribe. I did this to rule out the chance that a single provider's IP just wasn't flagged by Microsoft.



Looking at the sign in logs, one attempt showed a jump from New York to Amsterdam in under two hours, which is a real example of impossible travel by definition. Even so, none of these attempts generated a risk detection in Identity Protection.

7:53 PM	99025e1c-350a-41e...	Test User 1	Azure Portal	Success	0	175.110.113.114	Amsterdam, Noord-...	Success	Not Agentic	Multifactor authentic...
6:21 PM	5f9eea57-ab30-4e1c...	Test User 1	Azure Portal	Success	0	2600:4040:49f5:b500...	New York, New York...	Success	Not Agentic	Multifactor authentic...
8:00 PM	cc0ef27e-a966-4b15...	Test User 1	Azure Portal	Success	0	169.150.218.20	Amsterdam, Noord-...	Success	Not Agentic	Multifactor authentic...
7:59 PM	1e25d01c-a8b1-4b8...	Test User 1	Azure Portal	Success	0	169.150.218.20	Amsterdam, Noord-...	Success	Not Agentic	Multifactor authentic...
9/26/2026, 4:39:54 PM	19f9778e-9bcc-4caa...	Test User 1	Azure Portal	Success	0	146.70.250.27	Aberdeen, Hong Kon...	Success	Not Agentic	Multifac
9/26/2026, 4:34:06 PM	a0bb160f-be94-4a7...	Test User 1	Azure Portal	Success	0	146.70.250.27	Aberdeen, Hong Kon...	Success	Not Agentic	Multifac

Risk detections

Learn more Download Refresh Columns Got feedback?

Want to allow automatic risk remediation? Set up risk policies in Conditional Access. Learn more →

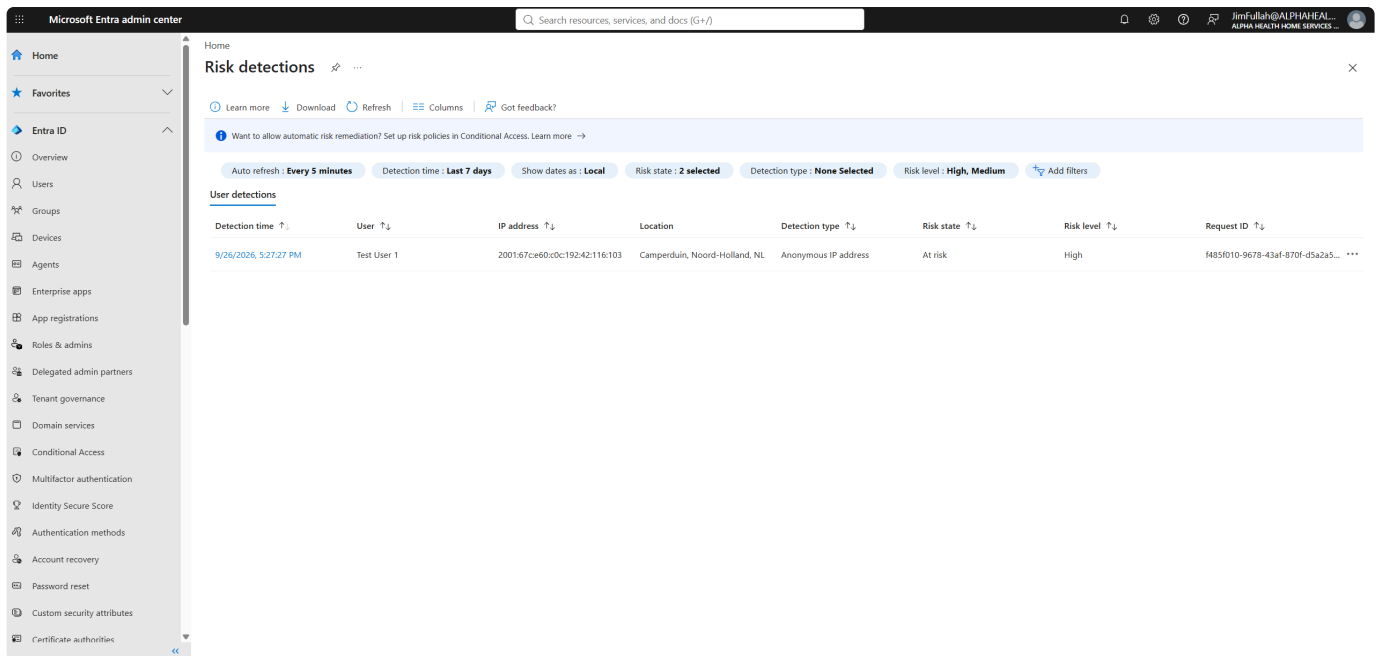
Auto refresh: Every 5 minutes Detection time: Last 7 days Show dates as: Local Risk state: 2 selected Detection type: None Selected Risk level: High, Medium Add filters

User detections

Detection time ↑↓	User ↑↓	IP address ↑↓	Location	Detection type ↑↓	Risk state ↑↓	Risk level ↑↓	Request ID ↑↓
No risk events found							

Microsoft's own documentation on simulating risk detections actually confirms this can happen. Their guide states there is a chance these steps will not trigger a detection, since the risk engine relies on machine learning models and known threat data rather than a simple rule. Consumer VPN IPs are not always on Microsoft's watch list, especially in a brand new trial tenant with very little sign in history to build a baseline from.

Following Microsoft's own recommended method, I tried again using the Tor Browser instead on a separate device, signing in as testuser1 through myapps.microsoft.com. This time it worked. The sign in was flagged in real time as an anonymous IP address detection, with a risk level of High and an attack type of obfuscation and access using a valid account. Tor exit nodes are much more reliably included on Microsoft's threat intelligence list than a typical consumer VPN, which is likely why this attempt succeeded where the others did not.



Detect and respond via Identity Protection

Head back to our original Jim Fullah account where we will detect the unusual sign in. In Entra ID protection there is a risky sign-ins section where we will review the "Comprised Account". We see 3 logs for testuser1 all at risk for 2 mediums and 1 high. Two Anomalous token/Anonymous IP entries at 5:33 PM show a different location code than the 5:27 PM detection, likely reflecting slightly different IP geolocation resolution between events

Learn more

Download

Refresh

Columns

Got feedback?

Want to allow automatic risk remediation? Set up risk policies in Conditional Access. [Learn more](#)

Auto refresh: **Every 5 minutes**

Detection time: **Last 7 days**

Show dates as: **Local**

Risk state: **2 selected**

Detection type: **None Selected**

Risk level: **High, Medium**

Add filters

User detections

Detection time	User	IP address	Location	Detection type	Risk state	Risk level	Request ID
26/2026, 5:33:35 PM	Test User 1	2a0fd000:0255:199	SE	Anonymous IP address	At risk	Medium	9b9cd3fc-61ff-47ea-a9b1-99a31e... ***
26/2026, 5:33:35 PM	Test User 1	2a0fd000:0255:199	SE	Anomalous token	At risk	Medium	9b9cd3fc-61ff-47ea-a9b1-99a31e... ***
26/2026, 5:27:27 PM	Test User 1	2001:67ce60:c0c192:42:116:103	Camperduin, Noord-Holland, NL	Anonymous IP address	At risk	High	f485f010-9678-43af-870f-d5a2a5... ***

Once clicking the detection hyperlink we get additional information. These tab informs us more about the client sign in device, browser, type of attack and policies applied. We see that our 'Risk-Based Sign-In MFA

and Require MFA for all users was successfully applied and not the our block legacy policy.

Risky Sign-in Details

User's risk report

User's sign-ins

User's risky sign-ins

User's risk detections

Sign-in's risk detections

Basic info

Device info

Risk info

Multifactor authentication info

Conditional Access

Report-only

9/26/2026, 5:33 PM

Anonymous IP address (At risk)

Time detected

9/26/2026, 5:33 PM

Risk state

Real-time

Risk level

Medium

Risk detail

-

Source

Identity Protection

Detection last updated

9/26/2026, 5:35 PM

Sign-in time

9/26/2026, 5:33 PM

IP address

2a0fd00:0:255:199

Sign-in location

SE

Sign-in client

Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:140.0) Gecko/20100101 Firefox/140.0

Token issuer type

Microsoft Entra ID

9/26/2026, 5:33 PM

Anomalous token (At risk)

Time detected

9/26/2026, 5:33 PM

Risk state

Real-time

Risk level

Medium

Risk detail

-

Source

Identity Protection

Detection last updated

9/26/2026, 5:35 PM

Sign-in time

9/26/2026, 5:33 PM

IP address

2a0fd00:0:255:199

Sign-in location

SE

Sign-in client

Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:140.0) Gecko/20100101 Firefox/140.0

Risk Detection Details

User's risk report

User's sign-ins

User's risky sign-ins

Linked risky sign-in

User's risk detections

Detection type

Anonymous IP address

Risk state

At risk

Risk level

High

Risk detail

-

Attack type(s)

Obfuscation/Access using proxy. Access using a valid account (Detected Offline)

Source

Identity Protection

Detection timing

Real-time

Activity

Sign-in

Detection time

9/26/2026, 5:27 PM

Detection last updated

9/26/2026, 5:30 PM

Token issuer type

Microsoft Entra ID

Sign-in time

9/26/2026, 5:27 PM

IP address

2001:67ce60:c0c:192:42:116:103

Sign-in location

Camperduin, Noord-Holland, NL

Sign-in client

Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:140.0) Gecko/20100101 Firefox/140.0

Sign-in request id

f485f010-9678-43af-870f-d5a2a5b15700

Sign-in correlation id

01a0df9c-8209-7fc8-97ac-348e4f84841f

Risky Sign-in Details

User's risk report

User's sign-ins

User's risky sign-ins

User's risk detections

Sign-in's risk detections

Basic info

Device info

Risk info

Multifactor authentication info

Conditional Access

Report-only

Search

Policy Name	Grant Controls	Session Controls	Result
Require MFA for all Users	Require multifactor authentica...		Success
Risk Based Sign in MFA	Require multifactor authentica...		Success
Block Legacy Authentication	Block		Not Applied

A sign-in can also be interrupted (e.g. blocked, multifactor authentication challenged) because of a user risk policy or sign-in risk policy. Currently, this tab only lists Conditional Access policies.

After reviewing details we can confirm user compromised by clicking the options above. This tells Entra you've investigated and determined this is a real compromise, not a false positive. Screenshot the confirmation.

Risky sign-ins

Download

Learn more

Export Data Settings

Configure trusted IPs

Troubleshoot

Select

Confirm sign-in(s) compromised

Confirm sign-in(s) safe

Dismiss sign-in(s) risk

Refresh

Columns

Got feedback?

Want to allow automatic risk remediation? Set up risk policies in Conditional Access. Learn more →

Auto refresh: Off

Date: Last 7 days

Show dates as: Local

Request ID equals 9b9cd3fc-61ff-47ea-a9b1-99a31e242100

Risk state: 2 selected

Risk level (real-time): None Selected

Risk level (aggregate): None Selected

Detection type(s): None Selected

Sign-in Type: 2 selected

Add filters

Date	User	IP address	Location	Risk state
9/26/2026, 5:33:35 PM	Test User 1	2a0f.d00:0:255::199	SE	At risk

Users can also have detections not linked to sign-in activity. To see all the detections, go to Risk detections.

Initiated sign-in compromised confirmation

Successfully initiated the sign-in compromised confirmation process for 1 sign-in. It might take several minutes to complete the flow.

After confirming compromised account my email was notified for a detailed report. In the report we see percentage graph of risky users.



User at risk detected

We detected a new user with at least high risk in your AL
, directory. This might be because we noticed suspicious account activity or
we found their emails and passwords posted in a public location.

[View detailed report >](#)



[Privacy Statement](#)

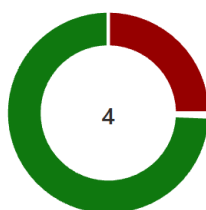
Microsoft Corporation, One [Microsoft Way, Redmond, WA 98052](#)



| Risky users ▾



Percentage of risky users at each risk level



■ High Risk ■ Medium Risk ■ Low Risk ■ No Risk

New risky users per day



■ Risky Users ■ Self Remediation Activity 1 more

✕ Confirm user(s) compromised ✓ Dismiss user(s) risk ✓ Confirm user(s) safe 🔍 Reset password ⬇ Download ↻ Refresh ⚙ Manage view ▾ 🗨 Got feedback?

Search Risky users

Add filter

Risk level : 2 selected

Risk last updated : None selected ✕

Risk state : 2 selected ✕

Status : Active ✕

Reset filters



Name ↑↓

Username

Risk state

Risk level

Risk last updated ↓



Test User 1

testuser1@

Confirmed compromised

High

Sep 26, 2026, 06:20 PM

In real world environments the best course of action is to reset password for the user and revoke sessions. Revoke session removes all sessions for the account on all devices. Once you reset password for user

they will be delivered a temporary password on the next sign in

Reset password



Test User 1

The user

'testuser1@AMERICANHEALTHHOMESERVICE.com@microsoft.com' will be assigned a temporary password that must be changed on the next sign in. To display the temporary password, click 'Reset password'.

Reset password

Home > Users



Test User 1
User

Search

Edit properties Delete Refresh Reset password Revoke sessions Manage view Got feedback?

Overview

Audit logs

Sign-in logs

Do you want to revoke all sessions for the user?

This will revoke all sessions for the user "Test User 1", requiring the user to re-sign in from all devices.

Yes

No

Conclusion

This lab walked through the full identity security lifecycle in Microsoft Entra ID, from hardening to detection to response. I started by locking down the environment with Conditional Access policies, requiring MFA for all users, blocking legacy authentication, and setting up risk based sign in policies and compliant device requirements for admin roles. I then learned how to read sign in logs and understood that Conditional Access evaluates policies individually per sign in rather than applying every policy uniformly.

The most valuable part of this lab was simulating a real compromised account scenario. My first few attempts using consumer VPNs did not trigger a detection, which turned out to be a real and documented limitation rather than a mistake on my part. Microsoft's own guide on simulating risk detections confirms that these outcomes are not always guaranteed. Switching to Tor Browser and following Microsoft's official method finally triggered a real, high risk anonymous IP address detection in real time.

From there I got to walk through the full detection and response workflow that a SOC analyst would actually use. I investigated the risk detection, confirmed the sign in as compromised, and took remediation action by revoking the user's active sessions and resetting their password. I also got an automated email alert from Microsoft, which showed me how this kind of detection reaches an analyst without them having to actively watch the dashboard.

Overall this lab gave me hands on experience with identity based attacks and defenses that go beyond just reading about them. Troubleshooting the parts that did not work the first time, like the P2 licensing, the domain naming issue, and the failed detection attempts, ended up teaching me just as much as the parts that worked smoothly. This is the kind of practical, real world problem solving I want to bring into a SOC analyst role.